مقيد

شركة القيروان لنظم المعلومات

خطة استمرارية الأعمال

برنامج الالتزام بالضوابط الأساسية للأمن السيبراني · مرحلة التشغيل

رقم الوثيقة	**QIS-BCP-001**
الإصدار	٠٫٤ (مسودة)
التاريخ	١١ نوفمبر ٢٠٢٦م
التصنيف	مقيد
إشارة المشاركة	برتقالي · TLP:AMBER

إعداد نايف السالم، قائد الحوكمة والمخاطر والالتزام

دراسة حالة افتراضية. شركة القيروان لنظم المعلومات (QIS) وموظفوها وعملاؤها جهات وشخصيات افتراضية أُعدّت لملف أعمال مهني، وأي تشابه مع جهة حقيقية غير مقصود. أما الجهات التنظيمية والأطر المذكورة فهي حقيقية. لغة الوثيقة. تصدر هذه الوثيقة باللغتين العربية والإنجليزية، وفي حال وجود تعارض بين النصين يُعتمد النص العربي.

ضبط الوثيقة

الدور	المسمى الوظيفي	الاسم	الحالة
المالك	الرئيس التنفيذي للتقنية	ريم العتيبي	قيد الانتظار
المُعِدّ	قائد الحوكمة والمخاطر والالتزام	نايف السالم	مكتمل
المصادِق	اللجنة الإشرافية للأمن السيبراني	—	قيد الانتظار
المعتمِد	الرئيس التنفيذي	فيصل الحربي	قيد الانتظار

سجل الإصدارات

الإصدار	التاريخ	المُعِدّ	التغيير
٠٫١	٥ نوفمبر ٢٠٢٦م	نايف السالم	المسودة الأولى للمراجعة
٠٫٢	٩ نوفمبر ٢٠٢٦م	نايف السالم	تسمية أعلى مستوى للمخاطر «كارثي» بدلاً من «حرج»
٠٫٣	١٠ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الهوية البصرية الجديدة وصفحة الغلاف، وتحسين قابلية القراءة، وإضافة وسوم أمن المعلومات (التصنيف، والعلامة المائية، وإشارة المشاركة وفق مستويات الهيئة الوطنية للأمن السيبراني)، واعتماد اسم الشركة «شركة القيروان لنظم المعلومات».
٠٫٤	١١ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الأرقام الهندية في جميع أرقام الوثيقة، وكتابة أرقام الضوابط بالترتيب المتبع في وثائق الهيئة الوطنية للأمن السيبراني، تيسيراً للبحث عنها في نصوص الهيئة.

دورة المراجعة: سنوياً على الأقل، وبعد كل تفعيل فعلي للخطة أو حادثة مرتفعة الخطورة، وعند إضافة خدمة أو عميل أو تغيير مزوّد السحابة.

التصنيف وإشارة المشاركة

الوسم	المستوى	ما يعنيه
التصنيف	مقيد	يؤدي الإفصاح غير المصرح به إلى ضرر محدود، ويقتصر الاطلاع على من تحددهم الشركة.

الوسم	المستوى	ما يعنيه
إشارة المشاركة (TLP)	برتقالي	مشاركة محدودة داخل جهة المستلم مع المعنيين فقط.

١. المقدمة

تضمن هذه الخطة استمرار الخدمات التي تقدمها شركة القيروان لنظم المعلومات لعملائها الحكوميين، واستعادتها ضمن الأزمنة المستهدفة عند وقوع حادثة أو كارثة، سواء كان مصدرها هجوماً سيبرانياً أو عطلاً تقنياً أو فقدان موقع أو أفراد. وهي تعالج الخطر R-17، وتدعم معالجة الخطرين R-07 وR-10g في سجل المخاطر.

٢. الأهداف

- استمرار الخدمات الحرجة للعملاء، وفي مقدمتها بوابة المواطنين لدى العميل (أ).
- استعادة الأنظمة ضمن زمن التعافي المستهدف (RTO) ونقطة الاستعادة المستهدفة (RPO) المحددين في القسم ٤.
- حماية بيانات العملاء وسلامتها أثناء الانقطاع والتعافي.
- الوفاء بالتزامات مستوى الخدمة في العقود، ومتطلبات الصمود في الضوابط الأساسية للأمن السيبراني (المكوّن الفرعي ٣-١).
- تعزيز جاهزية الشركة عبر الاختبار والتدريب الدوري.

٣. النطاق

تشمل الخطة الخدمات المستضافة للعملاء، والخدمات المُدارة، وخدمات تقنية المعلومات المؤسسية التي تعتمد عليها، والمقر الرئيس في الرياض ومكتب جدة، والموظفين الرئيسيين، والموردين الذين تعتمد عليهم الخدمات. ولا تشمل الخطة استمرارية أنظمة العملاء التي لا تديرها الشركة.

٤. تحليل أثر الأعمال

حُددت أهداف التعافي لكل خدمة بحسب مستوى العميل وأثر انقطاعها. وتُعد هذه القيم مقترحة حتى تُطابق مع مستويات الخدمة في عقود العملاء.

الخدمة	العميل	الأثر عند الانقطاع	أقصى توقف مقبول	RTO	RPO	الأولوية
بوابة المواطنين	أ	توقف خدمات المواطنين، وإخلال بعقد حرج قيد التجديد، وأثر على السمعة	٨ ساعات	٤ ساعات	١٥ دقيقة	١
الهويات والبريد (Active Directory و Microsoft 365)	الشركة	توقف دخول الموظفين إلى جميع الأنظمة، وتعطل التواصل مع العملاء	٨ ساعات	٤ ساعات	ساعة	١
الخدمات المُدارة والدعم عن بُعد	أ، ب، ج، هـ	عجز العملاء عن الحصول على الدعم، وتعطل أعمال موظفيهم	٨ ساعات	٤ ساعات	لا ينطبق	٢
نظام الخدمات الطلابية	ج	تعطل خدمات الطلاب في فترات التسجيل	٢٤ ساعة	٨ ساعات	ساعة	٢
نظام إصدار التراخيص	د	تأخر معالجة طلبات التراخيص	٤٨ ساعة	٢٤ ساعة	٤ ساعات	٣
مستودعات الشيفرة ومسار البناء	أ، و	تعذر إصدار التحديثات والإصلاحات الأمنية	٧٢ ساعة	٢٤ ساعة	٢٤ ساعة	٣
نظام المالية والموارد البشرية	الشركة	تأخر الرواتب والمدفوعات	٥ أيام	٧٢ ساعة	٢٤ ساعة	٤

٥. السيناريوهات واستراتيجيات الاستمرارية

السيناريو	الخدمات المتأثرة	استراتيجية الاستمرارية
هجوم برمجية فدية	قد تتأثر جميع الخدمات	عزل البيئات وفق خطة الاستجابة للحوادث، والاستعادة من نسخ احتياطية غير قابلة للتعديل خارج الموقع
انقطاع منطقة لدى مزوّد السحابة	الخدمات المستضافة	التشغيل في منطقة ثانوية داخل المملكة لدى المزوّد نفسه، مع تكرار البيانات
فقدان المقر الرئيس أو غرفة الخوادم	الهويات، والخدمات المُدارة، والمالية	العمل عن بُعد ومن مكتب جدة، والاعتماد على Microsoft 365 السحابية، واستعادة الخوادم الداخلية من النسخ خارج الموقع
تعطل أداة الإدارة عن بُعد أو مزوّدها	الخدمات المُدارة	أداة احتياطية معتمدة مسبقاً لدى العملاء، والدعم الهاتفي والحضوري للحالات الحرجة

السيناريو	الخدمات المتأثرة	استراتيجية الاستمرارية
غياب موظفين رئيسيين	جميع الخدمات	بديل موثق لكل دور حرج، وأدلة تشغيل مكتوبة، وحسابات طوارئ محفوظة بأمان

٦. مصفوفات الاستمرارية للخدمات ذات الأولوية

٦٫١ بوابة المواطنين (العميل أ)

الوصف	بوابة إلكترونية تقدم خدمات العميل (أ) للمواطنين، تبنيها الشركة وتستضيفها.
التبعيات	منصة مزوّد السحابة، وقاعدة البيانات، والنفاذ الوطني الموحد، وجدار حماية التطبيقات، ومسار البناء.
السيناريوهات	انقطاع منطقة السحابة، أو هجوم حجب خدمة، أو برمجية فدية، أو ثغرة تستلزم إيقاف البوابة.
مستوى الخطر	مرتفع (R-05، R-07، R-17).
إجراءات استباقية	تكرار قاعدة البيانات إلى منطقة ثانوية كل ١٥ دقيقة، ونسخ يومية غير قابلة للتعديل، وخدمة مكافحة حجب الخدمة، وتوثيق خطوات التحويل، واختبار سنوي.
أثناء الحادثة: الاستمرارية	عرض صفحة صيانة بالتنسيق مع العميل (أ)، وتحويل الحركة إلى المنطقة الثانوية بعد التأكد من سلامة البيانات.
أثناء الحادثة: التعافي	الاستعادة بالترتيب: قاعدة البيانات، ثم خادم التطبيقات، ثم واجهات البرمجة، ثم الواجهة، مع التحقق من سلامة البيانات قبل فتح الخدمة.
بعد الحادثة	التحقق من اكتمال البيانات مع العميل، وإعادة التشغيل من المنطقة الرئيسة في وقت منخفض الحركة، وتوثيق الدروس المستفادة.

٦٫٢ الهويات والبريد الإلكتروني

الوصف	خدمة Active Directory الداخلية المتزامنة مع Microsoft Entra ID، وبريد Microsoft 365.
التبعيات	خوادم Active Directory في غرفة الخوادم، والاتصال بالإنترنت، وخدمات Microsoft السحابية.
السيناريوهات	تعطل غرفة الخوادم، أو اختراق حساب إداري، أو برمجية فدية تصيب الخوادم الداخلية.
مستوى الخطر	مرتفع (R-02، R-07، R-10).
إجراءات استباقية	حسابا طوارئ سحابيان محفوظان بأمان، ونسخ احتياطية لـ Active Directory خارج الموقع، وخطة لتقليل الاعتماد على الخوادم الداخلية.

أثناء الحادثة: الاستمرارية	استمرار البريد والملفات عبر Microsoft 365 مباشرة، والدخول بحسابات سحابية مؤقتة للموظفين الرئيسيين.
أثناء الحادثة: التعافي	استعادة Active Directory من نسخة سليمة في بيئة نظيفة، وإعادة تعيين كلمات مرور الحسابات الإدارية وحسابات الخدمات.
بعد الحادثة	مراجعة جميع الحسابات المميزة، وتحديث إجراءات الاستعادة.

٦٫٣ الخدمات المُدارة والدعم عن بُعد

الوصف	الدعم الفني وإدارة الأجهزة ومراقبة الشبكات لموظفي العملاء (أ) و(ب) و(ج) و(هـ).
التبعيات	أداة الإدارة عن بُعد، وشبكات VPN للعملاء، ونظام تذاكر الدعم، والهويات، والفنيون.
السيناريوهات	تعطل أداة الإدارة عن بُعد، أو إيقافها عمداً أثناء حادثة، أو تعذر الوصول إلى المقر.
مستوى الخطر	كارثي قبل المعالجة (R-01، R-07).
إجراءات استباقية	أداة احتياطية معتمدة مسبقاً من كل عميل، وقائمة اتصال طوارئ بكل عميل، وتمكين الفنيين من العمل عن بُعد بأمان.
أثناء الحادثة: الاستمرارية	الدعم الهاتفي، وإرسال فنيين إلى مقار العملاء للحالات الحرجة، وإعطاء الأولوية للعميل (أ).
أثناء الحادثة: التعافي	إعادة تشغيل الأداة بعد تأكيد سلامتها من فريق الاستجابة، ثم إعادة الوصول لكل عميل على حدة بعد موافقته.
بعد الحادثة	مراجعة الصلاحيات الممنوحة أثناء الطوارئ وإلغاء المؤقت منها.

٧. تفعيل الخطة والأدوار

الدور	من يشغله	المسؤولية
قائد الاستمرارية	الرئيس التنفيذي للتقنية	يقرر تفعيل الخطة، ويقود استعادة الخدمات.
فريق إدارة الأزمة	الرئيس التنفيذي والرئيس التنفيذي للتقنية والرئيس التنفيذي للمالية	قرارات الأعمال والموارد، واعتماد التواصل الخارجي.
منسق العملاء	رئيس تقديم الخدمات	إبلاغ العملاء وتنسيق الأولويات معهم.
قائد الاستجابة للحوادث	قائد الحوكمة والمخاطر والالتزام	تنسيق المسار الأمني إذا كان السبب حادثة سيبرانية.

الدور	من يشغله	المسؤولية
فرق التعافي	الاستضافة، والعمليات التقنية، والتطوير	تنفيذ إجراءات الاستعادة وفق المصفوفات.

معايير التفعيل: يُفعِّل قائد الاستمرارية الخطة عندما يُتوقع أن يتجاوز انقطاع أي خدمة ذات أولوية ١ أو ٢ نصف زمن التعافي المستهدف لها، أو عند فقدان المقر الرئيس، أو بطلب من قائد الاستجابة للحوادث.

التواصل: يتبع التواصل مع العملاء والجهات التنظيمية خطة التواصل في خطة الاستجابة للحوادث (QIS-IRP-001، القسم ٩).

٨. اختبار الخطة وصيانتها

النشاط	الدورية	التفاصيل
اختبار التحويل لبوابة المواطنين	سنوياً	تحويل فعلي إلى المنطقة الثانوية خارج أوقات الذروة، وقياس زمن التعافي الفعلي مقارنة بالمستهدف.
اختبار الاستعادة من النسخ الاحتياطية	ربع سنوي	استعادة عينة من الأنظمة، ومنها Active Directory.
تمرين محاكاة	سنوياً	سيناريو فقدان المقر الرئيس أو برمجية فدية، بالاشتراك مع خطة الاستجابة للحوادث.
مراجعة الخطة	سنوياً	وعند أي تغيير في الخدمات أو العملاء أو مزوّد السحابة، وتحديث قوائم الاتصال كل ربع سنة.

بنود تحتاج إلى تأكيد: مطابقة أهداف التعافي في القسم ٤ مع مستويات الخدمة في كل عقد، وتأكيد توفر منطقة ثانوية داخل المملكة لدى مزوّد السحابة، واعتماد الأداة الاحتياطية للإدارة عن بُعد لدى كل عميل.